

Gerenciamento de Riscos em TI



gerenciamento de riscos em TI pode ser compreendido como as políticas, normas, procedimentos e tecnologias que uma empresa adota para reduzir ameaças, vulnerabilidades e os impactos que podem surgir em decorrência do não tratamento de um ou mais ameaças. Para que possamos entender melhor a importância do gerenciamento de riscos na TI, temos que em primeiro lugar, compreender alguns conceitos que fazem parte desse gerenciamento, a saber: (a) vulnerabilidade – pode ser definida como ponto fraco ou fraqueza que um ou mais ativos de TI possui e que pode ser explorado por uma ou mais ameaças; (b) consequência ou impacto – representa o dano causado a uma empresa decorrente da exploração de uma ou mais vulnerabilidades por uma ou mais ameaças, ocasionando assim uma perda ou dano a empresa; © risco – é a exposição potencial a perdas ou danos decorrentes da concretização de uma ou mais ameaças e o impacto causado por elas a empresa.

No contexto da segurança da informação e segurança cibernética, o risco tem o potencial de afetar diversos aspectos da empresa, tais como: (a) os objetivos do modelo de negócio; (b) a continuidade dos serviços prestados; © os resultados; (d) a reputação ou imagem comercial; (e) os ativos de TI e toda a infraestrutura que sustenta o bom funcionamento; dentre outros.

Como exemplo de riscos relacionados à TI, citamos: (a) ameaças físicas – resultantes de acesso físico não autorizado ou danos a recursos de TI, como servidores, estações de trabalho, etc., incluindo roubo, danos causados por desastres naturais, incêndio, inundação ou acesso não autorizado a dados confidenciais por um colaborador ou não; (b) ameaças eletrônicas – são aquelas que comprometem os ativos de TI, como, por exemplo, os códigos maliciosos (malwares, ransomwares, worms, trojans, dentre outros) que podem infectar dispositivos e sistemas computacionais causando a perda da disponibilidade, integridade ou confidencialidade; © falhas técnicas – bugs, erros de programação ou falhas na cópia de segurança são exemplos de falhas técnicas, que podem causar algum dano e assim proporcionar a indisponibilidade ou perda da integridade de um ou mais ativos de TI; (d) falhas de infraestrutura – qualquer tipo de falha que ocorra em qualquer parte da infraestrutura de TI da empresa, como por exemplo a perda da conectividade da rede, indisponibilidade de links de

comunicação, falhas em elétricas decorrentes de pane no grupo gerador ou nobreaks, dentre outros; (e) falhas humanas – podem ser classificadas como não intencionais decorrentes de erros humanos por falta de conhecimento ou treinamento e, intencionais, quando o indivíduo realiza de forma intencional e ilícita um ato que pode causar como consequência algum dano ou perda a empresa.

Para que a empresa realize um gerenciamento de riscos eficiente é preciso começar pela identificação exata dos seguintes itens: (a) os tipos de ameaças que podem afetar o modelo de negócio e os ativos de TI; (b) as vulnerabilidades presentes nos ativos de TI que podem ser exploradas pelas ameaças; e, por fim, © os danos e impactos que podem ocorrer em consequência das não tratativas das vulnerabilidades.

Neste contexto a área de gestão de riscos em conjunto com a área da segurança da informação ou segurança cibernética da empresa deve construir uma Matriz de Riscos;

Matriz de Risco

A matriz de risco pode ser compreendida como a análise da probabilidade versus o impacto de um determinado risco, permitindo assim que a empresa possa calcular e avaliar a severidade do risco.

A matriz de risco é um processo de análise das ameaças e vulnerabilidades com relação a probabilidade versus impactos causados em decorrência dos danos ou perdas. Seu objetivo é auxiliar a organização a reconhecer e mapear todos os riscos relacionados aos ativos de TI, classificando-os de acordo com a sua severidade.

Existem duas metodologias predominantes para avaliar os diferentes tipos de riscos de TI. A saber:

(a) avaliação quantitativa de riscos de TI – tem como objetivo medir o risco usando valores monetários. Esse tipo de avaliação utiliza fórmulas matemáticas para fornecer o valor das perdas esperadas associadas a um risco específico com base no valor do ativo, na frequência da ocorrência do risco e na probabilidade de perda associada. Como exemplo citamos a falha de um servidor. Uma avaliação quantitativa envolve (a) observar: o custo do servidor e/ou a receita que ele gera para a empresa; (b) a frequência com a qual o servidor trava ou fica indisponível e; © a perda financeira

estimada em decorrência do travamento ou indisponibilidade do servidor. A partir dessas informações e valores, pode-se fazer cálculos importantes tais como: (a) expectativa de perda única – custos referentes a concretização do incidente; (b) taxas anuais de ocorrência – refere-se a quantidade de vezes por ano que a empresa pode esperar que o risco ocorra e, por fim © expectativa de perda anual – refere-se ao valor total do risco ao longo de um ano.

(b) avaliação qualitativa de risco de TI – baseia-se no julgamento para categorizar os riscos com base na probabilidade e no impacto e utiliza-se uma escala de classificação para descrever os riscos, exemplo: risco baixo, risco médio e risco alto. Por exemplo: vamos supor que precisamos classificar com “alta prioridade” algo que você espera que aconteça várias vezes por ano. Daí você faz o mesmo para custo/impacto em quaisquer termos que pareçam úteis, tais como: (a) baixo – perderia até meia hora de produção; (b) médio – causaria o desligamento completo por pelo menos 2 dias; © alto – causaria perda irrevogável para o modelo de negócio. De posse dessas classificações, você poderia então criar a matriz de avaliação de riscos para auxiliá-lo a categorizar o nível de risco para cada evento de risco e, com isso obter os resultados necessários que irão possibilitar as decisões de quais riscos serão necessários o tratamento e que tipos de tratamento serão realizados.

É importante ressaltar que independente do tipo de avaliação que irá escolher para avaliar os riscos de TI é essencial que se utilize diferentes tipos de informações nas avaliações de risco de TI. Ou seja, você pode utilizar dados quantitativos para avaliar o valor dos ativos de TI e a expectativa de perda, mas também pode envolver os colaboradores de sua empresa para obter outros dados e informações específicos, possibilitando como resultado final uma maior compreensão dos riscos e a escolha dos tratamentos mais eficientes para os riscos avaliados.

Tratamento de Riscos de TI

Com relação ao tratamento dos riscos relacionados aos ativos de TI, podemos realizá-los de três formas, a saber: (a) mitigação – envolve o tratamento direto do risco pelas equipes de TI, podendo esse tratamento ser realizado através de recursos internos. O objetivo principal aqui é realizar o tratamento das vulnerabilidades de forma direta; (b) transferência – neste caso, a empresa decide transferir o tratamento do risco a um terceiro, pôr em alguns casos não possuir a expertise necessária para mitigar o risco. Uma analogia simples é o seguro de um carro realizado por uma pessoa que realiza a

transferência de todos os riscos associados ao carro para a seguradora; © aceitação – em alguns casos é possível que os processos internos para mitigar o risco ou os valores para a transferência do tratamento do risco a um terceiro fiquem maior que o próprio risco. Neste contexto, a organização simplesmente aceita que o risco ocorra, tendo ciência de todos os danos e perdas associadas ao risco.

Gestão de Risco e Compliance (conformidade)

A gestão de risco e compliance refere-se à prática de identificar, analisar e tratar de forma antecipada os potenciais riscos associados ao modelo de negócio que a organização realiza. Podemos ainda compreender a gestão de risco e compliance como a arte de gerenciar riscos e não conformidades da melhor maneira possível, considerando os recursos que a organização possui e as leis, normas e obrigações regulatórias que está sujeita a seguir ou obedecer. Cabe aqui, apenas citar que a “não conformidade” pode ser entendida como tudo aquilo que está em desacordo com as leis, normas e obrigações regulatórias.

Para a realização de uma boa gestão de risco e compliance ou também conhecido como “GRC”, a empresa deve: (a) compreender quais são as conformidades que precisam ser atendidas e quais são os riscos associados a essas conformidades; (b) compreender qual é a sua tolerância com relação a um risco que esteja associado a uma conformidade. Cabe aqui citar que quanto maior for a tolerância da empresa ao risco, menor será a sua exigência com relação a políticas, normas, regras e procedimentos internos de conformidade; © assegurar a conformidade de seus processos em relação aos riscos. Ou seja, garantir que os processos de conformidade que possui estejam de acordo com os riscos.

Conteúdo Bônus

Um pouco mais sobre gerenciamento de riscos em TI:

- Perspectiva Inovadora para a Gestão de Riscos em TI

Disponível no canal XP Educação, no YouTube.

- IBGC: Por que estamos falando tanto de Compliance e Governança?

Disponível no canal IBC Oficial, no YouTube.

Referência Bibliográfica

FONTES, E. **Praticando a segurança da informação.** – 2ªEd. Rio de Janeiro. Brasport, 2008.

HARRIS, Shon. **CISSP All-in-one, 3. ed.** Nova York, McGraw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas.** 2.ed. São Paulo; Elsevier, 2017.

ASSI, Marcos. **Governança, Risco e Compliance: Mudando a conduta nos negócios** – Edição Padrão, São Paulo Saint Paut, 2017.

FERNANDES, Aguinaldo Aragon. ABREU, Vladimir Ferraz. **Implementando a Governança de TI: da estratégia à gestão dos processos e serviços – 4ª Ed.** Brasport – Rio de Janeiro 2014.